Insper

Fundamentos Parte 2
Prof. Dr. Rodolfo Avelino

Fundamentos de Rede em Nuvem

Este módulo aborda os fundamentos de segurança em ambientes de nuvem, com foco em Virtual Private Cloud (VPC), sub-redes (Subnets), grupos de segurança (Security Groups) e listas de controle de acesso à rede (Network ACLs). São apresentados os mecanismos oferecidos pelas principais plataformas de Infraestrutura como Serviço (IaaS): Amazon Web Services (AWS), Microsoft Azure e Google Cloud Platform (GCP). O objetivo é compreender como proteger os recursos computacionais a partir do desenho e controle do tráfego de rede virtual.

1. Virtual Private Cloud (VPC)

1.1. Conceito e arquitetura

Uma VPC é uma rede virtual isolada logicamente dentro da infraestrutura do provedor de nuvem. Ela permite controlar todo o ambiente de rede virtualizado — desde a definição dos endereços IP até a configuração de roteamento e conectividade externa.

Na AWS, a VPC é o componente central da segurança de rede. Ela permite:

- Definir intervalos de IP usando notação CIDR (por exemplo, 10.0.0.0/16).
- Criar sub-redes públicas e privadas em múltiplas zonas de disponibilidade.
- Utilizar gateways para conectar a rede local (VPN ou Direct Connect).

A Figura 1 ilustra uma VPC com sub-redes públicas e privadas distribuídas em zonas de disponibilidade, com componentes como Internet Gateway e NAT Gateway.

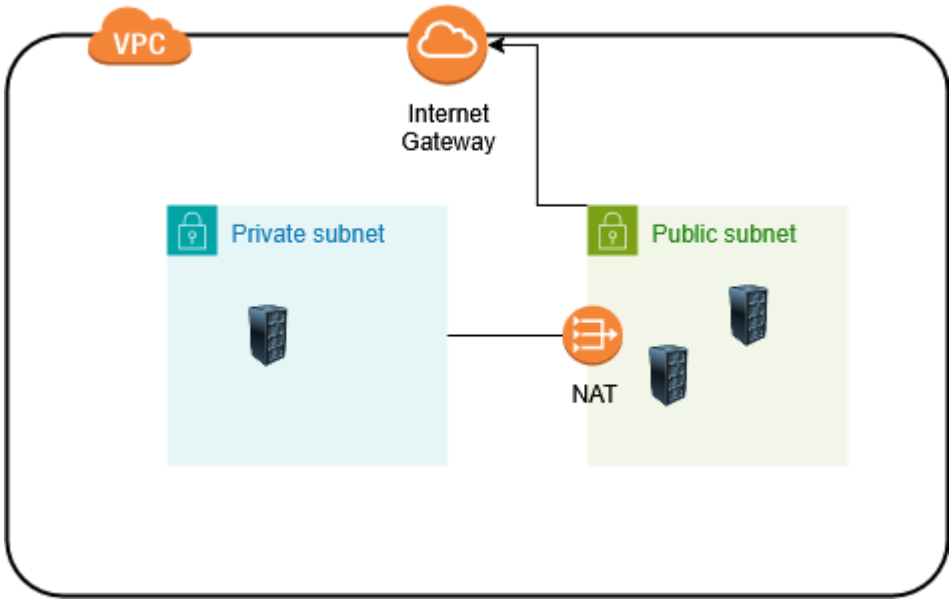


Figura 1: VPC com subet publica e privada

Na Azure, a estrutura equivalente é chamada de *Virtual Network* (VNet). Além da segmentação por sub-redes, a Azure permite integração nativa com o Azure Active Directory para controle de identidade, e o uso de Network Security Groups (NSGs) para controle de tráfego.

Na GCP, a VPC (Virtual Private Cloud) é chamada simplesmente de Rede VPC. É um serviço que permite criar uma rede virtual isolada dentro do Google Cloud, onde você pode executar seus recursos como máquinas virtuais (VMs) e outros serviços.

1.2. Segurança em VPC

As VPCs possibilitam diversas medidas de segurança:

- Isolamento lógico: VPCs são isoladas entre si, impedindo comunicação, salvo configuração explícita.
- Controle de tráfego: O roteamento e as listas de controle determinam quais redes podem acessar os recursos.
- Acesso privado a serviços gerenciados: Serviços como S3 ou DynamoDB na AWS podem ser acessados sem exposição à Internet via VPC Endpoints.

1.3. Sub-redes e Segurança

Conceito

As sub-redes são divisões dentro de uma VPC, associadas a zonas de disponibilidade. São utilizadas para segmentar os recursos em diferentes camadas de aplicação e níveis de acesso.

- Sub-redes públicas possuem rotas para um Internet Gateway, permitindo comunicação com a Internet.
- Sub-redes privadas não tem acesso direto à Internet. Para saída, utilizam mecanismos como o NAT Gateway.

Boas Práticas

- Separar ambientes de frontend, backend e banco de dados em sub-redes distintas.
- Restringir comunicação entre sub-redes por meio de tabelas de rotas específicas.

- Utilizar NAT Gateway para saída controlada da rede privada.

2. Controle de Tráfego: Tabelas de Rotas, Security Groups e NACLs

2.1. Tabela de Rotas

Definem para onde o tráfego é direcionado dentro da VPC. Cada sub-rede possui uma tabela de rotas associada. Boas práticas indicam a criação de tabelas personalizadas para cada sub-rede, permitindo regras específicas por camada de aplicação.

2.2. Security Groups

São firewalls virtuais aplicados no nível da instância. Suas principais características:

- Stateful: o retorno de uma conexão permitida é automaticamente autorizado.
- Filtram por porta, protocolo e origem/destino, podendo usar blocos CIDR ou outros grupos.
- Permitem segmentação por função (ex: grupos para frontend, backend, banco).

2.3. Network ACLs (NACLs)

São firewalls aplicados no nível da sub-rede. Suas principais diferenças em relação aos Security Groups:

- Stateless: cada pacote é avaliado individualmente (sem manter o estado da conexão).
- Permitem negar tráfego explicitamente (coisa que Security Groups não fazem).

- Devem ser configuradas com cuidado para não bloquear tráfego essencial entre sub-redes.

A utilização conjunta de Security Groups e NACLs é recomendada para defesa em profundidade.

2.4. Diferença entre Security Groups e Network ACLs

Agora que entendemos os conceitos fundamentais de Security Groups (SGs) e Network Access Control Lists (NACLs), vamos compará-los em detalhes para identificar quando e como utilizá-los em uma arquitetura de nuvem segura.

Network ACL (Lista de Controle de Acesso à Rede)

- Escopo de Aplicação:
  - Atua no nível da sub-rede, filtrando todo o tráfego que entra ou sai dela.
  - Ideal para políticas de segurança amplas, aplicáveis a múltiplos recursos dentro de uma mesma sub-rede.
- Comportamento:
  - Stateless: Não mantém registro de conexões ativas. Se uma regra permite tráfego de entrada (inbound), é necessário criar outra regra explícita para o tráfego de saída (outbound).
  - Avaliação Sequencial: As regras são processadas em ordem numérica (ex.: regra 100 antes da 200). A primeira regra que corresponder ao tráfego será aplicada, ignorando as demais.
- Flexibilidade:
  - Permite permitir (ALLOW) ou negar (DENY) tráfego específico, funcionando como um firewall tradicional.

- Útil para bloquear faixas de IP maliciosas ou restringir comunicações entre sub-redes.
- Desafios:
  - Pode se tornar complexo em ambientes com muitas sub-redes, exigindo um grande número de regras.
  - Como é transparente para os recursos, um erro de configuração pode impactar todos os serviços na sub-rede.

Security Group (Grupo de Segurança)

- Escopo de Aplicação:
  - Atua no nível do recurso individual (ex.: instância EC2, banco de dados RDS).
  - Permite políticas granulares, como restringir acesso a uma única instância ou serviço.
- Comportamento:
  - Stateful: Mantém o estado das conexões. Se uma regra permite tráfego de entrada, o retorno é automaticamente autorizado, sem necessidade de regra de saída explícita.
  - Avaliação Combinada: Todas as regras associadas a um recurso são consolidadas, priorizando as mais específicas.
- Flexibilidade:
  - Apenas permite (ALLOW) tráfego – não há opção para regras de negação explícita (DENY).
  - Ideal para definir acessos mínimos necessários (princípio do menor privilégio).
- Desafios:

- Precisa ser associado manualmente a cada recurso, aumentando o risco de esquecimento em ambientes dinâmicos.
- Depende de uma gestão cuidadosa para evitar aberturas excessivas de portas.

2.5. Usando Security Groups e NACLs em Conjunto

Embora possam ser aplicados separadamente, a combinação dos dois oferece uma defesa em profundidade:

1. NACLs para Controle Global:
   - Bloquear faixas de IP suspeitas em toda a sub-rede.
   - Restringir tráfego entre ambientes (ex.: produção e desenvolvimento).
2. Security Groups para Proteção Granular:
   - Limitar acesso SSH/RDP apenas a endereços IP confiáveis.
   - Isolar bancos de dados, permitindo conexões apenas de servidores específicos.

Exemplo Prático:

- Um NACL pode bloquear todo o tráfego externo à sub-rede de banco de dados **(**DENY 0.0.0.0/0**).**
- Um Security Group na instância do banco de dados libera acesso apenas da sub-rede de aplicação (ALLOW 10.0.1.0/24).

3. Internet Gateway

Insper

O Internet Gateway (IGW) é um componente essencial para permitir que instâncias dentro de uma VPC tenham acesso direto à Internet pública. Ele atua como o ponto de entrada e saída da VPC para a rede externa.

Como funciona:

- O IGW é associado a uma VPC específica.
- Para que uma instância possa acessar a Internet:
    - Deve estar em uma sub-rede com uma rota para o IGW.
    - Deve possuir um IP público ou um *Elastic IP*.
    - As regras dos Security Groups e NACLs devem permitir o tráfego.

Exemplo prático:

Imagine que você precisa disponibilizar um site para o público. Para isso:

1. Crie uma sub-rede pública e associe uma tabela de rotas que aponte para o IGW.
2. Lance uma instância EC2 com um webserver instalado com IP público nessa sub-rede.
3. Configure as regras de entrada do Security Group permitindo acesso nas portas 80 (HTTP) e 443 (HTTPS).

Com isso, seu site poderá ser acessado de qualquer lugar da Internet.

4. NAT Gateway

Insper

O NAT Gateway (ou uma instância NAT) na prática e por recomendação de arquitetura permite que instâncias em sub-redes privadas iniciem conexões com a Internet, sem que possam ser acessadas externamente.

Como funciona:

- O NAT é criado em uma sub-rede pública.
- A sub-rede privada deve ter uma rota apontando para o NAT Gateway.
- As instâncias privadas usam esse gateway como saída.

Exemplo prático:

Você tem uma aplicação com dois servidores:

- Um servidor web público.
- Um banco de dados em uma sub-rede privada, que precisa baixar atualizações de segurança da Internet.

Para permitir isso de forma segura:

1. Crie um NAT Gateway na sub-rede pública.
2. Altere a tabela de rotas da sub-rede privada para enviar tráfego externo via NAT.
3. Garanta que o banco não tenha IP público e que suas portas estejam fechadas para entrada.

O banco de dados poderá buscar atualizações, mas não será acessível de fora.

Resumindo:

Insper

Característica	Internet Gateway	NAT Gateway
Acesso	Entrada e saída	Somente saída
Local de uso	Sub-redes públicas	Sub-redes públicas (para tráfego da privada)
Exposição à Internet	Sim (exige IP público)	Não expõe instâncias privadas
Direção do tráfego	Bidirecional	Unidirecional (saída)
Exemplo de uso	Servidor web	Servidor de backend ou banco